

An OWL-Based Ontology for NIS2 Article 21 Compliance

A formal, machine-readable framework for representing and evaluating cybersecurity risk-management obligations.

- Candidate: Abdul Kader
- Supervisor: Prof. Enrico Francesconi
- Focus: problem, method, implementation, results, and limits

OWL 2 DL

SHACL

SPARQL



UNIVERSITÀ
DEGLI STUDI
FIRENZE

Scuola di Scienze Matematiche, Fisiche e Naturali
Corso di Laurea Magistrale in Informatica

Tesi di Laurea

UN'ONTOLOGIA OWL PER LA CONFORMITÀ ALLA DIRETTIVA NIS2
ARTICOLO 21: FRAMEWORK DI VALIDAZIONE E RAGIONAMENTO
AUTOMATIZZATO PER LE MISURE DI GESTIONE DEL RISCHIO DI
CYBERSICUREZZA

AN OWL-BASED ONTOLOGY FOR NIS2 DIRECTIVE ARTICLE 21
COMPLIANCE: AUTOMATED VALIDATION AND REASONING
FRAMEWORK FOR CYBERSECURITY RISK-MANAGEMENT MEASURES

ABDUL KADER

Relatore: Prof. Enrico Francesconi

Anno Accademico 2025-2026

Page | 1

Thesis cover page from the dissertation

Research problem and objective

Motivation for a formal compliance model

- NIS2 Article 21 requires technical, operational, and organizational measures.
- Assessment is often manual and difficult to reproduce consistently.
- The thesis turns Article 21 into a machine-readable model.

What the thesis contributes

- OWL 2 DL ontology covering Article 21(2) measure categories.
- SHACL constraints for missing or incomplete evidence.
- A compact web app for inspection, querying, and visualization.

Research objective

Transform legal obligations into a structured compliance artifact that can be checked, queried, and explained.

Article 21 measure map

The thematic areas that structure the ontology model



Ten Article 21 thematic areas summarized as a compact visual map

Why this image matters

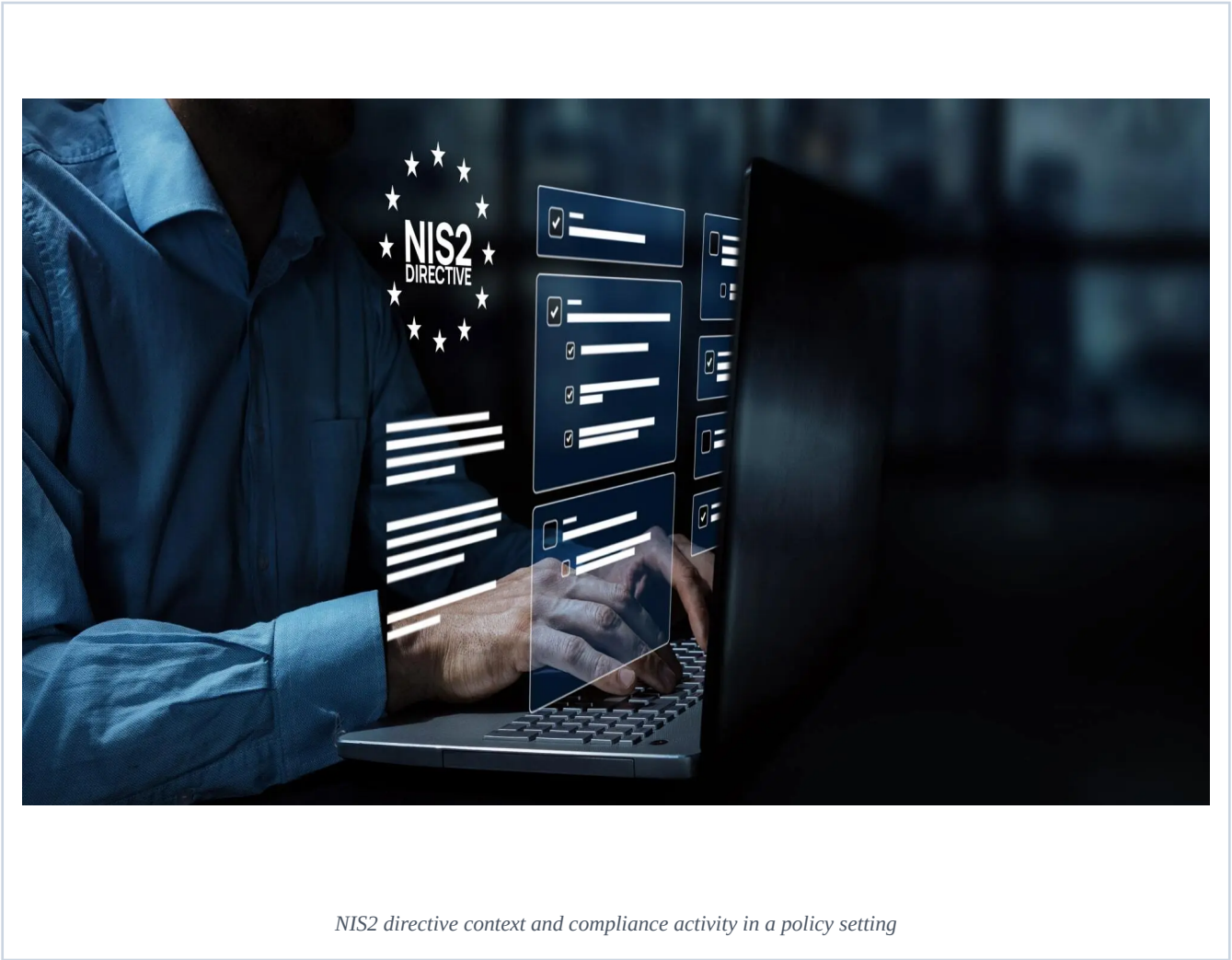
- It gives a compact overview of the Article 21 scope before the ontology is introduced.
- It is directly aligned with the legal measure categories that the thesis formalizes.
- It supports the claim that the model is grounded in the structure of the directive, not an abstract re-labeling exercise.
- The ontology then refines these areas into the twelve operational classes used for reasoning.

Bridge to the model

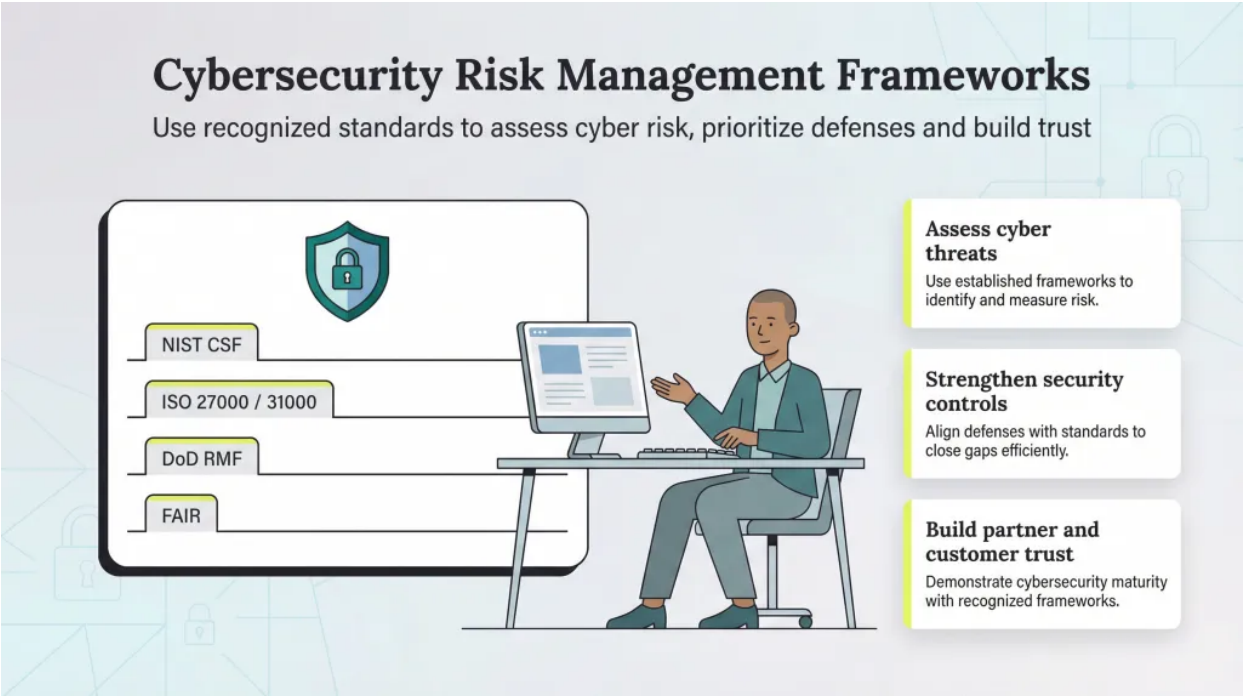
This visual is justified because it maps directly to the thesis scope: the ontology, validation rules, and compliance output are all derived from these thematic areas.

Regulatory and standards context

Positioning NIS2 Article 21 within cybersecurity risk management



NIS2 directive context and compliance activity in a policy setting



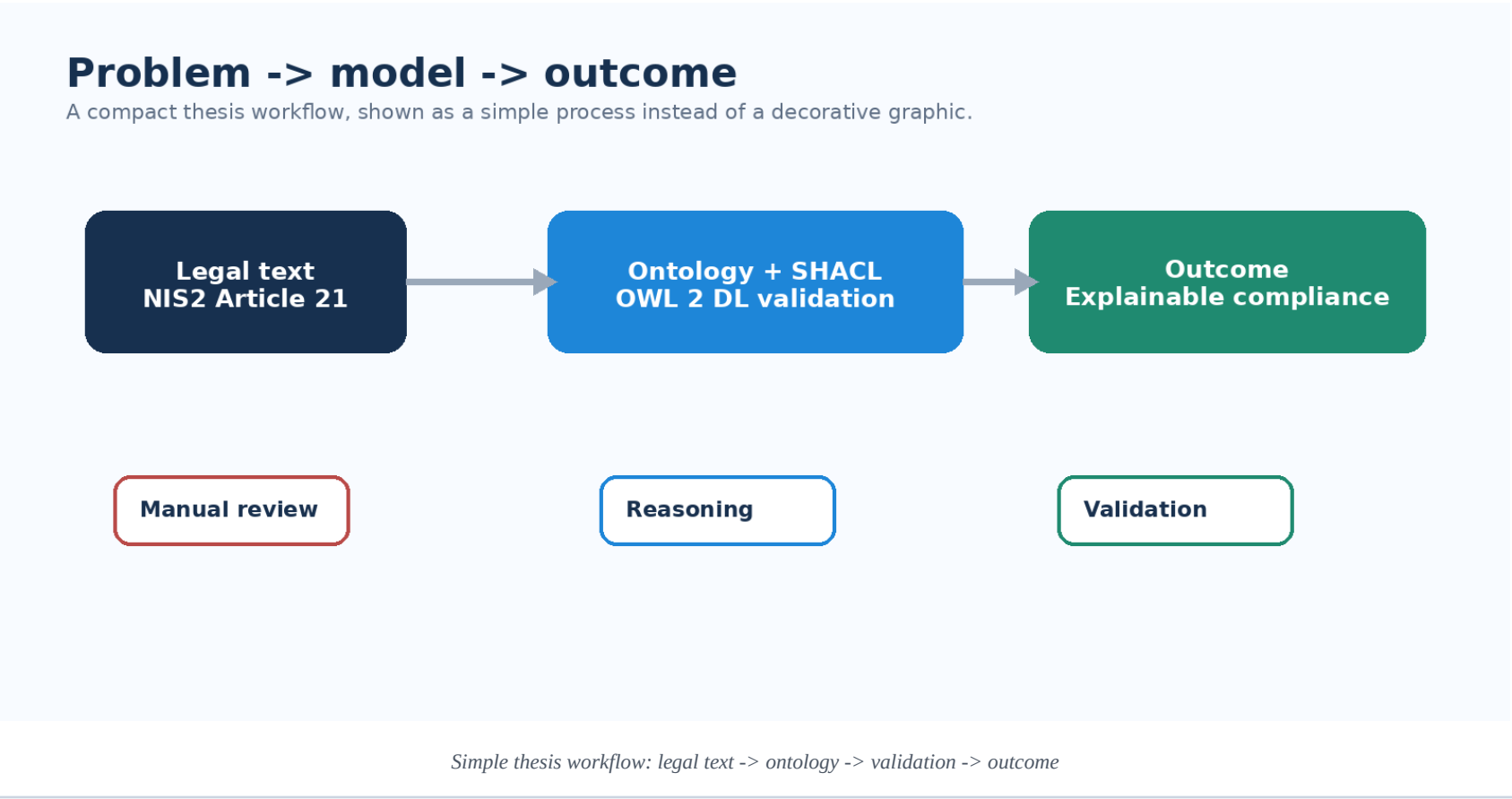
Recognized cybersecurity frameworks used to organize risk-management thinking

Analytical relevance

The presentation connects Article 21 with established cybersecurity governance concepts, so the ontology can be read as both a legal artifact and a risk-management model.

Methodological approach

From legal text to computable compliance



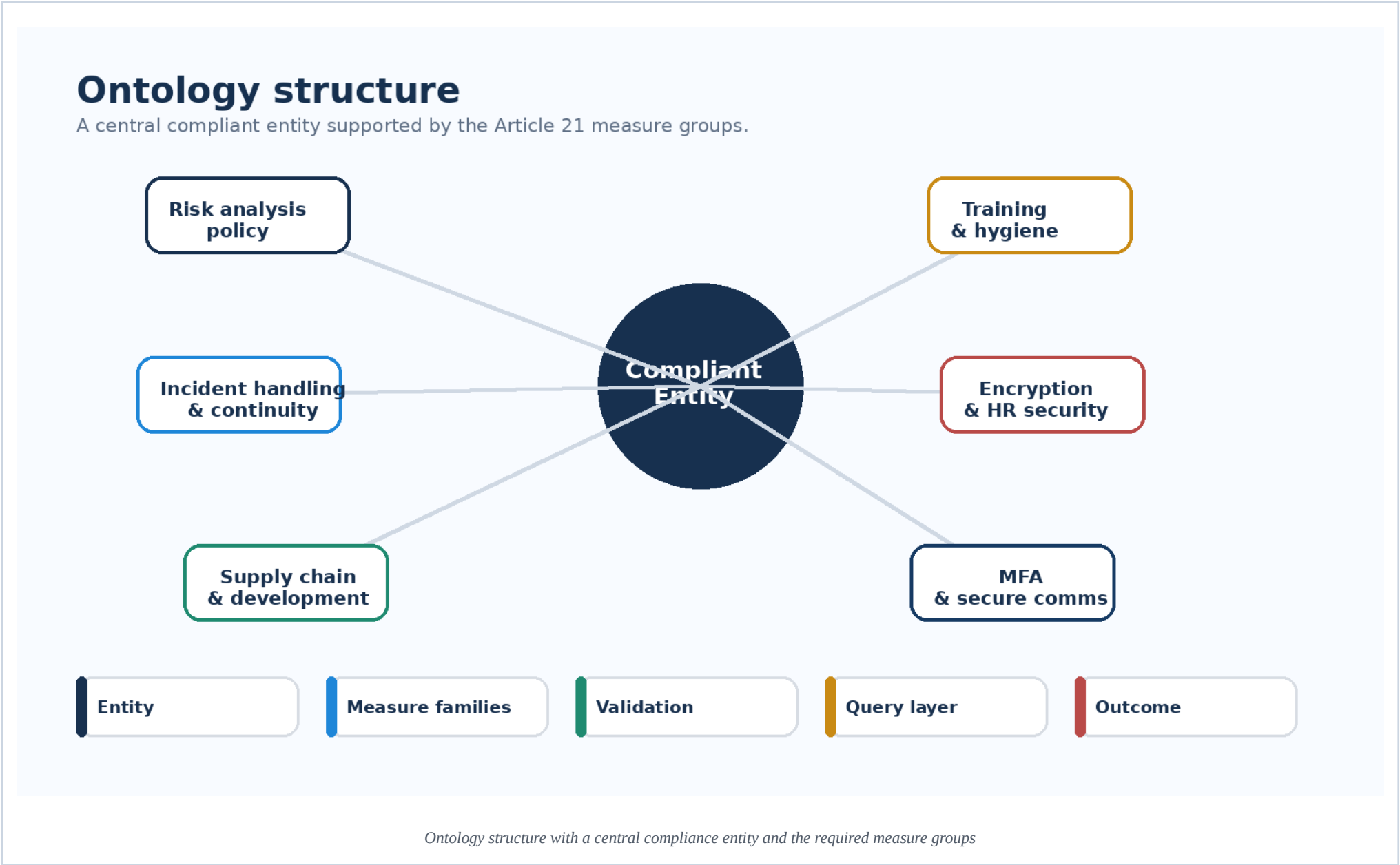
- Design-science: build the artifact and evaluate it against representative cases.
- OWL 2 DL supports classification and reasoning.
- SHACL checks whether required evidence is present.
- SPARQL supports inspection and querying.

Modeling decision

The thesis models the ten legal points as twelve operational classes, separating points (g) and (j) where the wording combines distinct concerns.

Ontology model

The structure that makes compliance computable



Key classes

- Entity and RiskManagementMeasure
- Technical, Operational, Organizational measures
- CybersecurityRisk and SecurityIncident

Analytical significance

- Preserves the link between legal provisions and model elements.
- Allows the reasoner to infer compliance-relevant classifications.
- Supports explanation rather than only a binary result.

Dissertation figures: ontology implementation

Selected implementation figures from Chapter 6

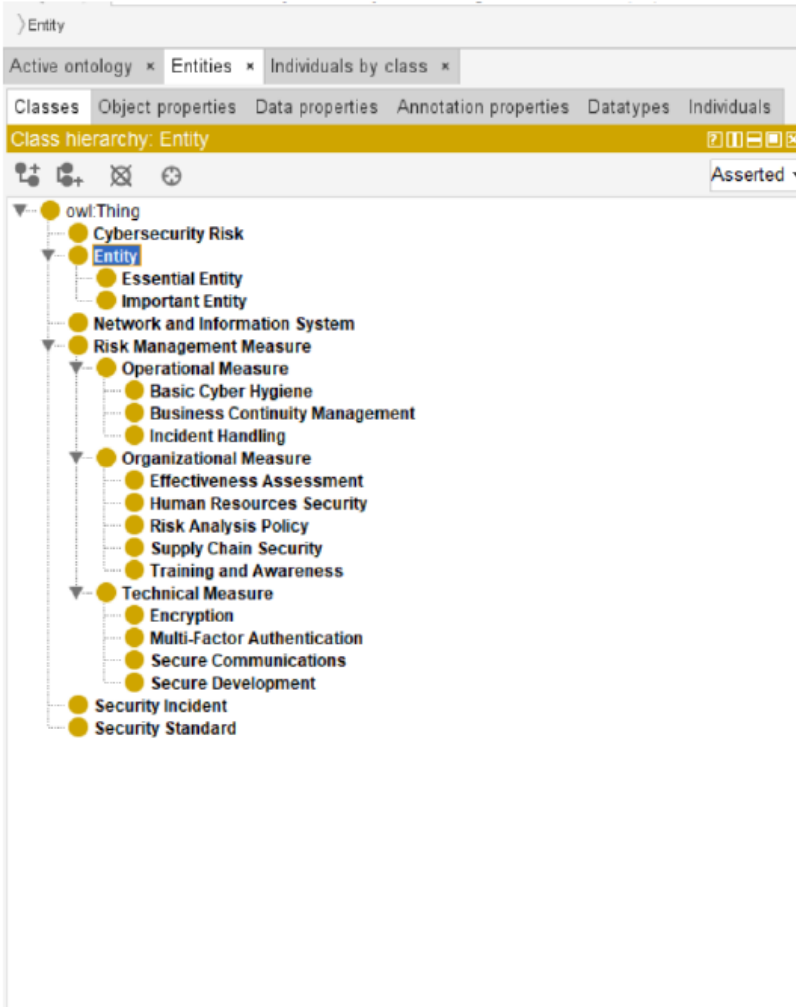


Figure 6.1: Protégé class hierarchy for the NIS2 Article 21 ontology

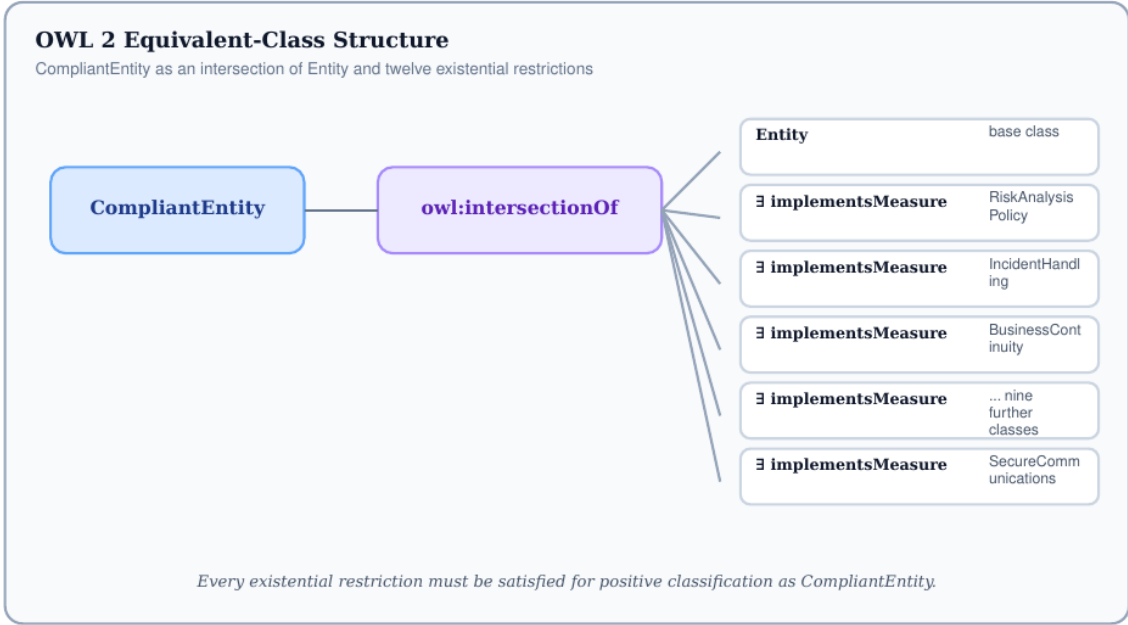


Figure 6.4: OWL equivalent-class structure for CompliantEntity

Figure 6.4: OWL equivalent-class structure for CompliantEntity

Interpretation

These figures show that the thesis artifact is implemented, not just conceptual. The ontology was built in OWL, inspected in Protégé, and centered on a compliance class covering the Article 21 measure categories.

Validation and results

Prototype-level evaluation findings

Art. 21(2)	Legal obligation (abbreviated)	State of affair	Verdict
(a)	Risk analysis and information system security policies	Med Center Risk Analysis Policy implemented	COMPLIANT
(b)	Incident handling procedures and capabilities	Med Center Incident Handling implemented	COMPLIANT
(c)	Business continuity, backup management, disaster recovery	No measure asserted	VIOLATION
(d)	Supply chain security and supplier relationships	No measure asserted	VIOLATION
(e)	Security in NIS acquisition, development and maintenance	No measure asserted	VIOLATION
(f)	Policies to assess effectiveness of risk measures	No measure asserted	VIOLATION
(g)	Basic cyber hygiene practices and training	Basic Cyber Hygiene + Training Awareness	COMPLIANT
(h)	Policies regarding cryptography and encryption	Med Center Encryption implemented	COMPLIANT
(i)	Human resources security, access control, asset mgmt	No measure asserted	VIOLATION
(j)	MFA / continuous authentication + secured communications	MFA only; no Secure Communications	PARTIAL

Article 21(2)(j) warrants special attention: the ontology decomposes this norm into two operational classes — MultiFactorAuthentication and SecureCommunications — because the directive text covers both authentication solutions and secured voice/video/text communications. MedCenterHospital satisfies the authentication component but not the

Worked example from the thesis showing the partial healthcare case and verdicts

Observed outcome

12 / 12

Full coverage yields the inferred `CompliantEntity` class.

6 / 12

Partial coverage stays non-compliant and exposes the gaps.

Interpretation

- The result measures modeled coverage, not legal certification.
- Missing requirement categories are identified explicitly.

Comparison and limitations

Scope of contribution and stated boundaries

9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

Approach	Formal Semantics	Auto Reasoning	SPARQL	SHACL	Open Source
This thesis (OWL+SHACL)	Yes (OWL 2 DL)	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No

Comparison from the thesis: OWL + SHACL + SPARQL in one demonstrator

Strength

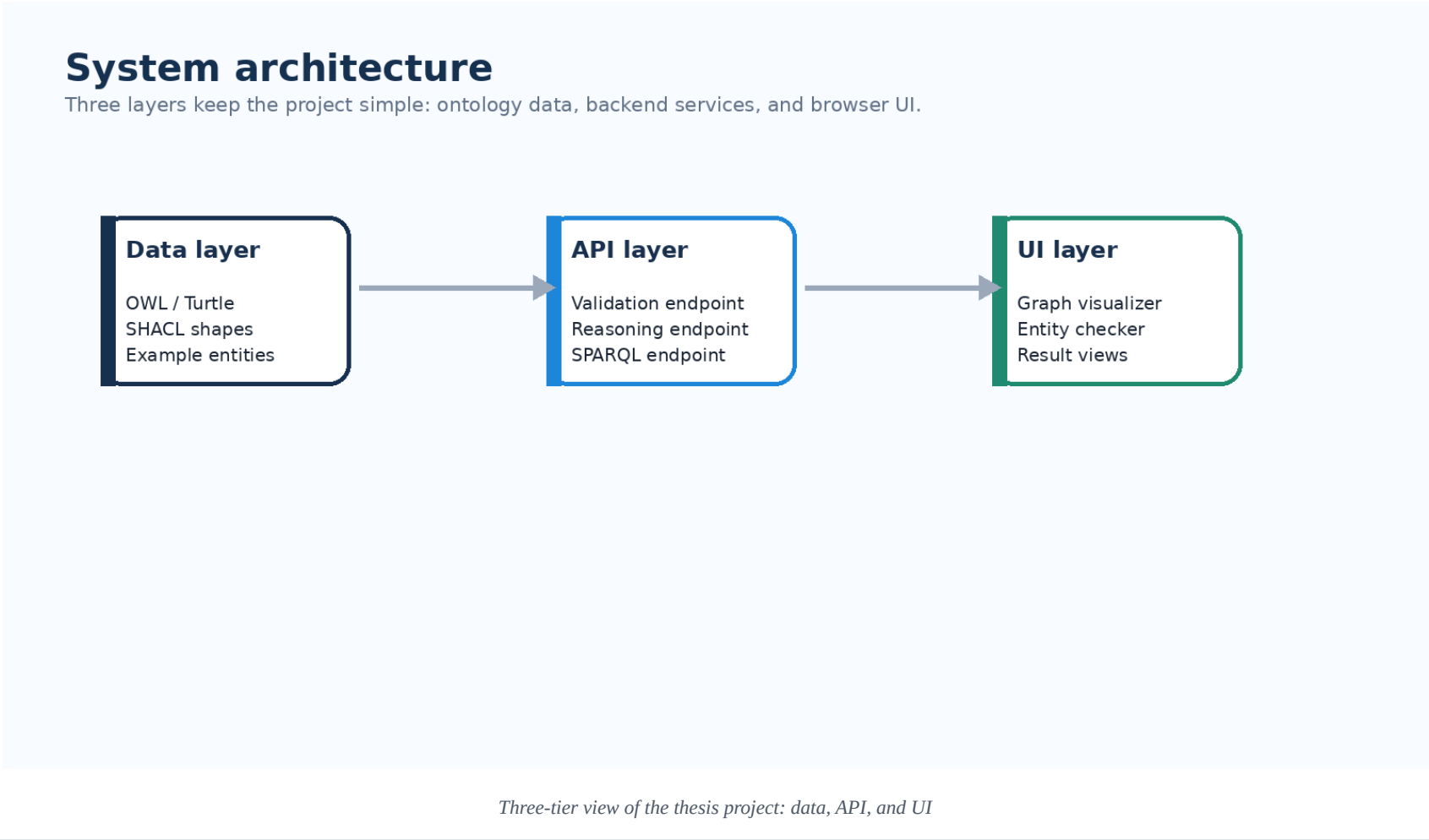
- Formal semantics through OWL 2 DL
- Constraint validation through SHACL

Limitations

- Reasoning is demonstrated within a bounded prototype setting.
- Production-grade evidence governance remains future work.

System architecture

Implementation structure of the prototype



- The ontology is stored as RDF/OWL and loaded by the backend.
- The API exposes validation, reasoning, and ontology-data endpoints.

Research questions

What the thesis set out to answer

Research questions

The presentation should answer these three things early and clearly.

**Can Article 21(2) be represented
as a layered ontology?**

**Which OWL axiom pattern best captures
compliance coverage?**

**How do SHACL and OWL complement
one another?**

Three research questions presented early, in a compact academic style

- RQ1: How can Article 21(2) be represented as a layered ontology?
- RQ2: Which OWL axiom pattern can express compliance coverage?

Technology stack

Standards and implementation technologies

Technology stack

The thesis uses a small, standard stack rather than a heavy custom system.



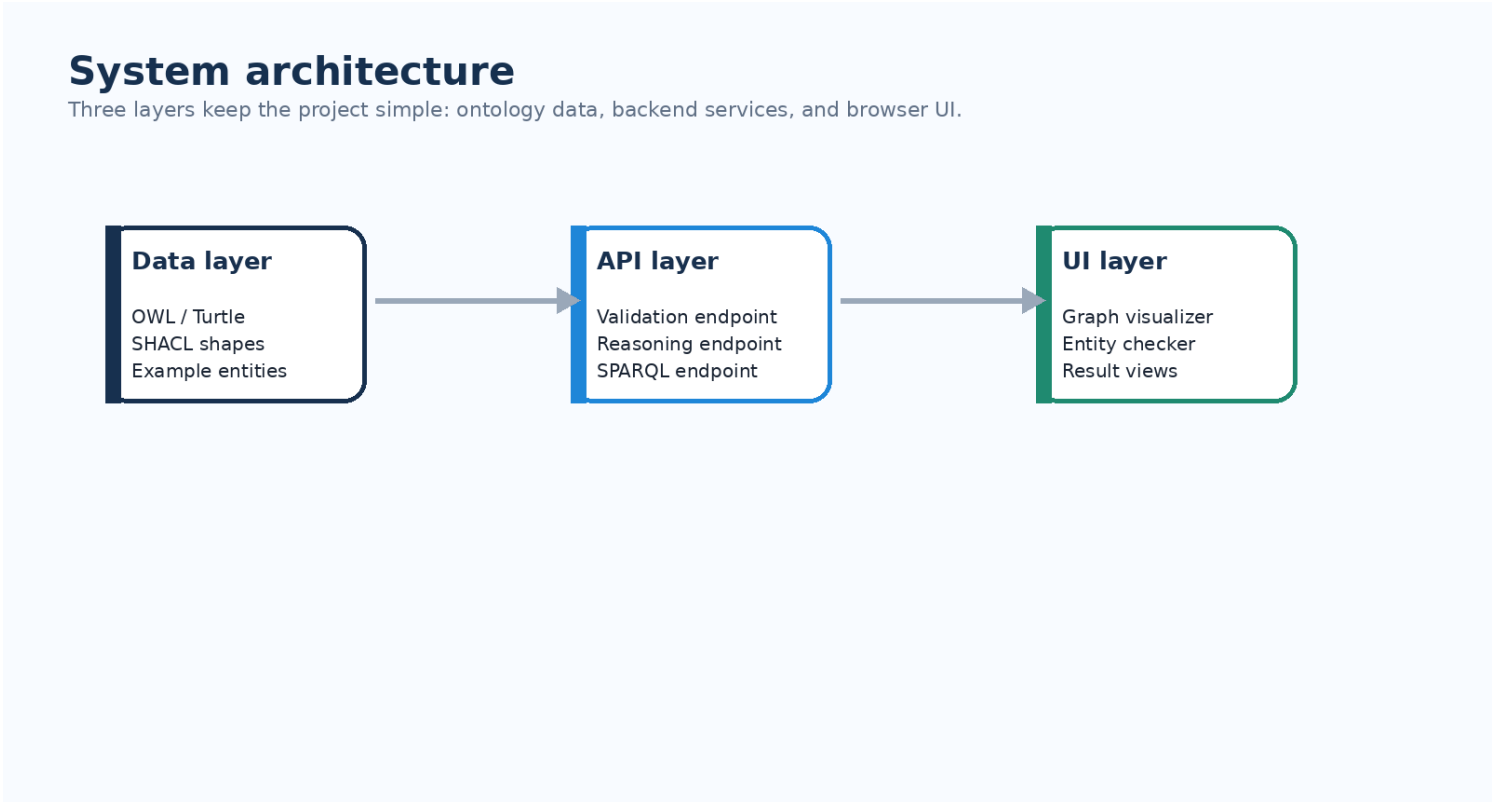
Why this matters

A small stack keeps the thesis reproducible, standard-based, and easier to explain in a defense.

- The stack is based on reproducible Semantic Web technologies.
- It keeps the thesis grounded in standards-based knowledge representation.

Prototype architecture

Inspectable implementation layer



Three-tier implementation used by the thesis prototype

Implementation note

The prototype loads the ontology, exposes validation and reasoning endpoints, and presents results in a browser view for inspection and demonstration.

Dissertation figures: ontology visualization

Graph excerpt from the implemented prototype

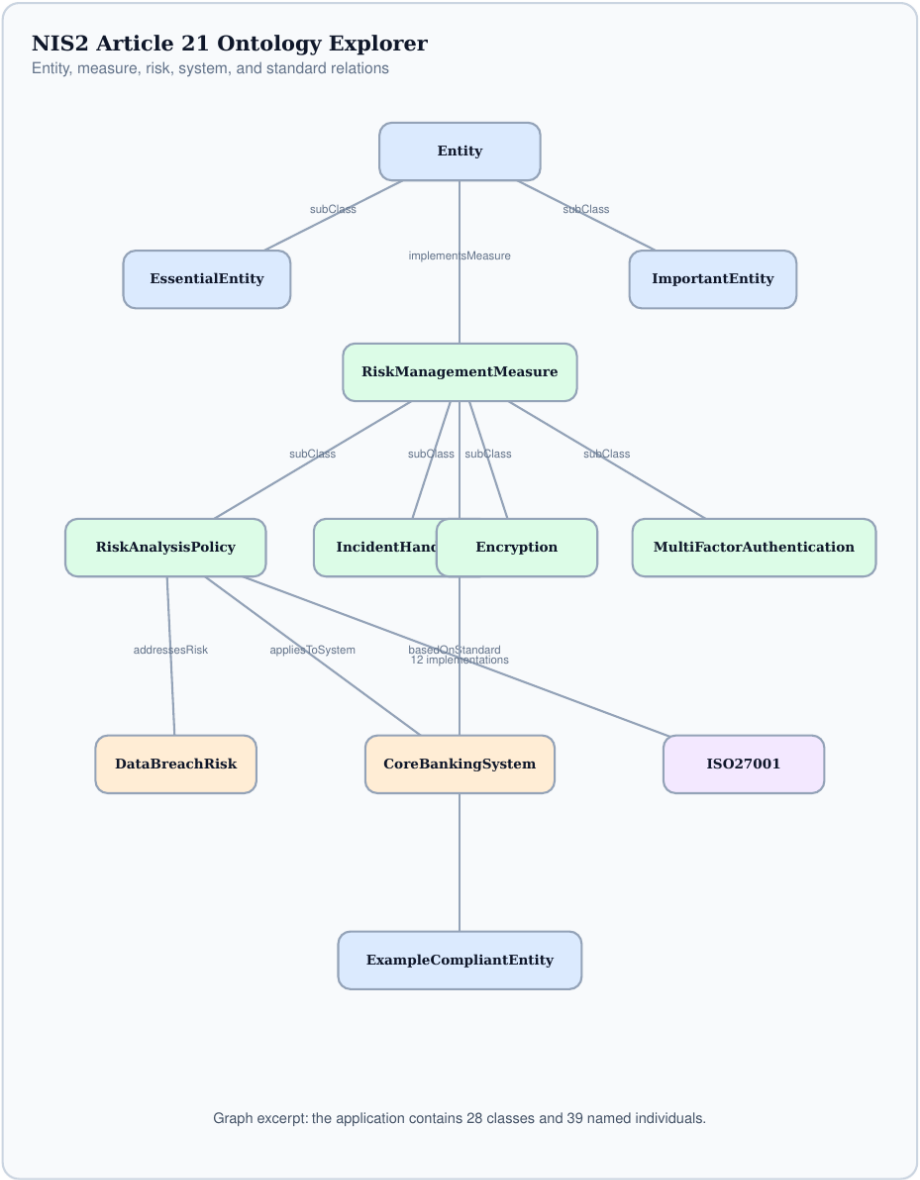


Figure 8.1: Ontology Explorer and Representative Relations

Figure 8.1: ontology explorer showing entity, measure, risk, system, and standard relations

Interpretive value

- Entities are connected to implemented measures.
- Measures are connected to systems, risks, and standards.

Connection to the research claim

This screenshot shows the bridge between the ontology vocabulary and the web-based inspection layer. It supports the claim that the model can be queried and explained, not only stored as a static file.

Dissertation figures: prototype outputs

Reasoning and real-time compliance assessment

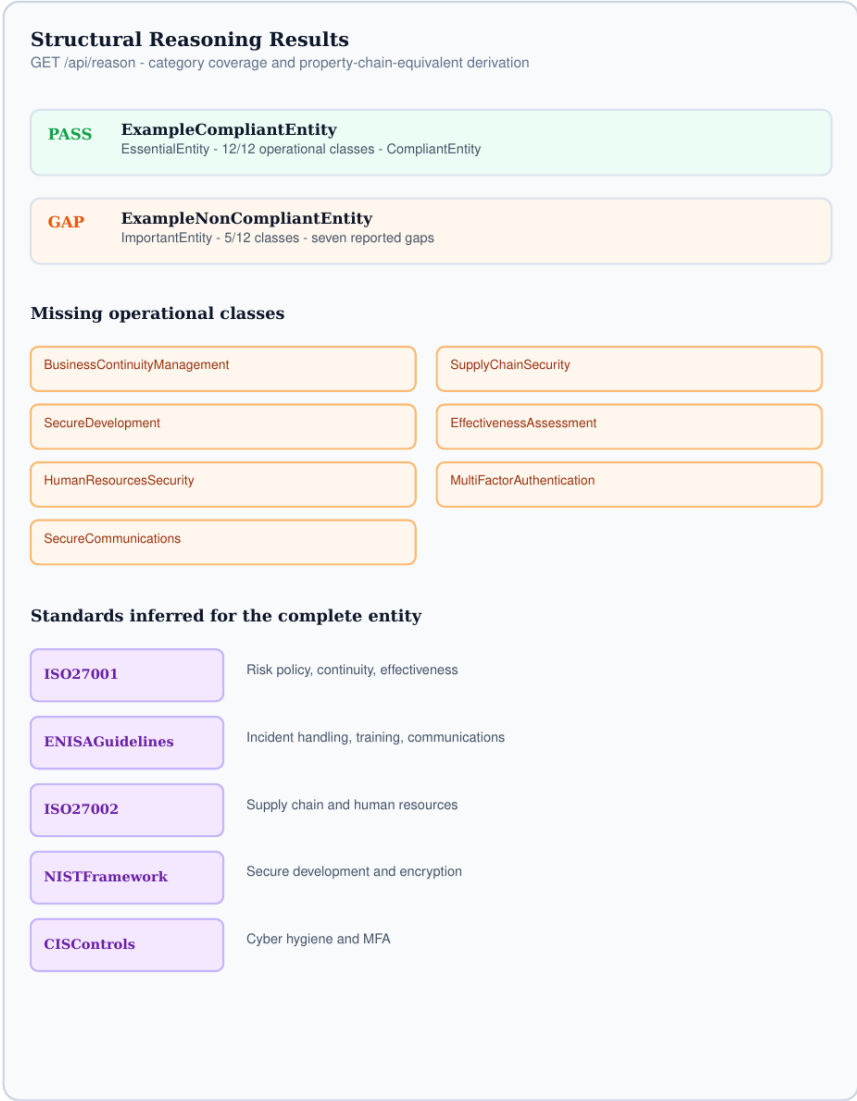
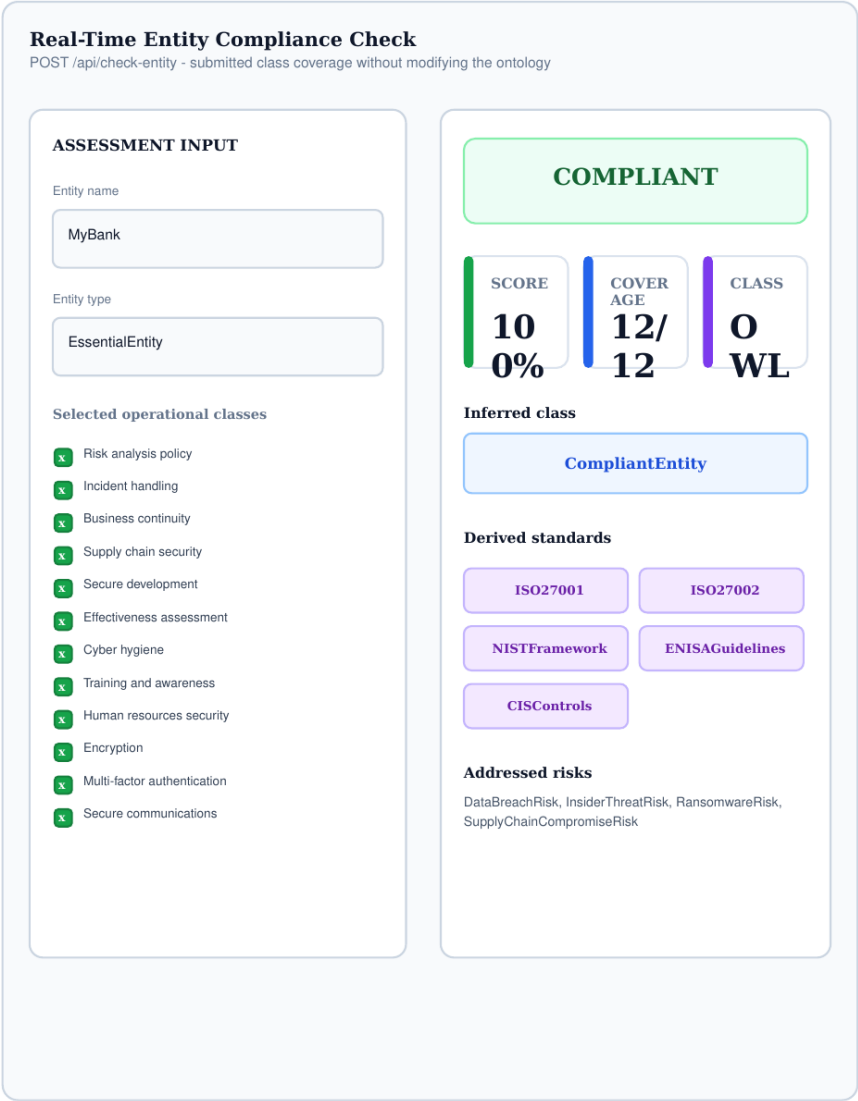


Figure 8.3: Entity Classification and Derived Standards

Figure 8.3: classification, missing classes, and derived standards



Dissertation figures: SPARQL query layer

Competency-question execution over the ontology graph

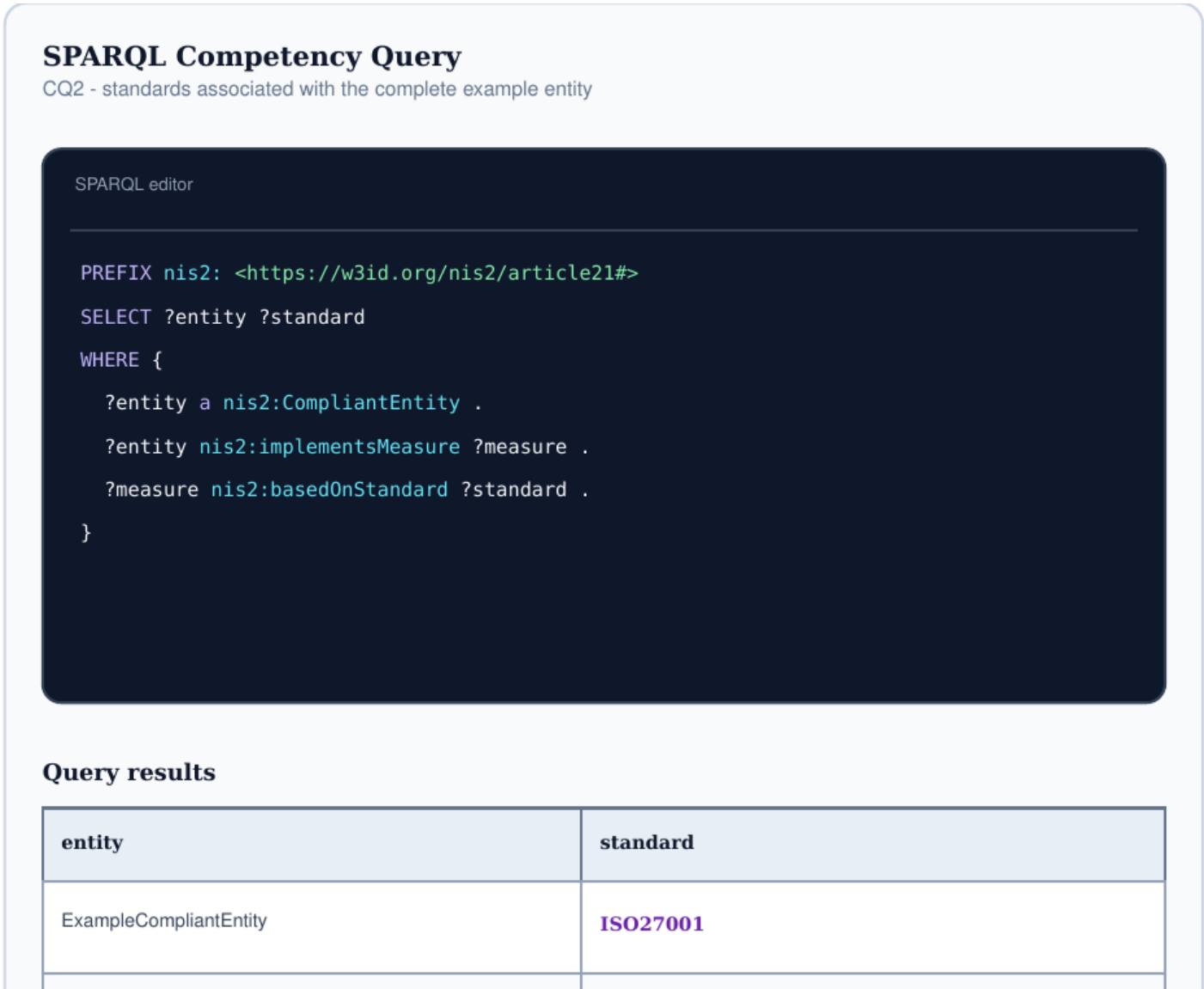


Figure 8.6: SPARQL competency query and result table

What this demonstrates

- The ontology can be inspected through query patterns.
- Standards linked to a compliant entity can be retrieved from the graph.

This slide completes the sequence: ontology representation, validation, reasoning, and information retrieval.

Conclusion

Final synthesis of the research contribution

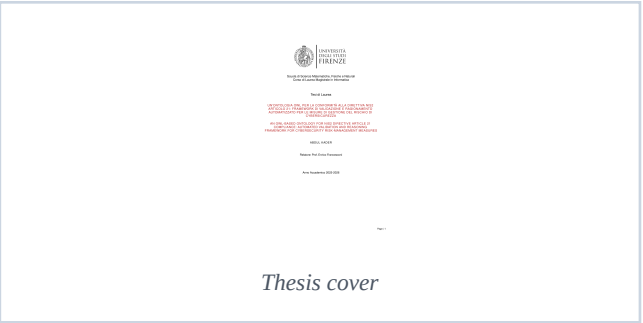
Takeaway

This thesis shows that NIS2 Article 21 compliance can be represented as a formal ontology, validated with SHACL shapes, queried with SPARQL, and explained through a compact web application.

Core claims

- Manual verification becomes more consistent through formal representation.
- A traceable ontology bridges legal text and compliance evidence.

Thank you



Thesis cover

Future work

Research extensions and validation requirements

Next steps

- Integrate the prototype with a standards-complete reasoner.
- Add evidence, provenance, and review metadata.
- Evaluate the system with realistic organizational data.

9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

Approach	Formal Semantics	Auto Reasoning	SPARQL	SHACL	Open Source
This thesis (OWL+SHACL)	Yes (OWL 2 DL)	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No

A concise reminder that the thesis combines semantics, validation, and querying.

Closing point

This work is a formal compliance demonstrator, not a production deployment.